

SIMATS ENGINEERING

CO4-AT3

COURSE NAME: Ethical Hacking COURSE CODE: ITA1407

1. Web Server Reconnaissance and Vulnerability Analysis

Theory

The possible attack vectors include directory traversal/hidden-directory discovery, SQL injection, Cross-Site Scripting (XSS), vulnerable Apache software, and poor input validation. An outdated web server may contain publicly known vulnerabilities.

The assessment starts with reconnaissance to identify the target host and running services. Nmap can identify open ports and service versions. Nikto can check common web-server weaknesses, while Gobuster can discover hidden directories. Burp Suite can then be used to inspect and test HTTP requests.

Commands

```
sudo apt update
```

```
sudo apt install nmap nikto gobuster burpsuite -y
```

```
nmap -sV -sC TARGET_IP
```

```
nikto -h http://TARGET_IP
```

```
gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt
```

```
nmap --script vuln TARGET_IP
```

```
Burpsuite
```

Defense

- Update Apache and all software regularly.
- Disable unnecessary services.
- Use a Web Application Firewall (WAF).
- Implement strong input validation.
- Use parameterized SQL queries.
- Apply HTTPS/TLS.
- Use secure authentication and session management.
- Monitor server logs continuously.
- Apply least-privilege permissions.

2. SQL Injection and XSS

Theory

SQL Injection occurs when an application directly places user input into SQL queries without proper validation or parameterization. Attackers may manipulate queries and access unauthorized database information.

Cross-Site Scripting (XSS) occurs when malicious JavaScript is inserted into web pages and executed in another user's browser.

The CIA impact is:

- Confidentiality: Sensitive customer/database information may be exposed.
- Integrity: Database records or web content may be modified.
- Availability: Malicious queries or application abuse may disrupt services.

Commands

Install tools:

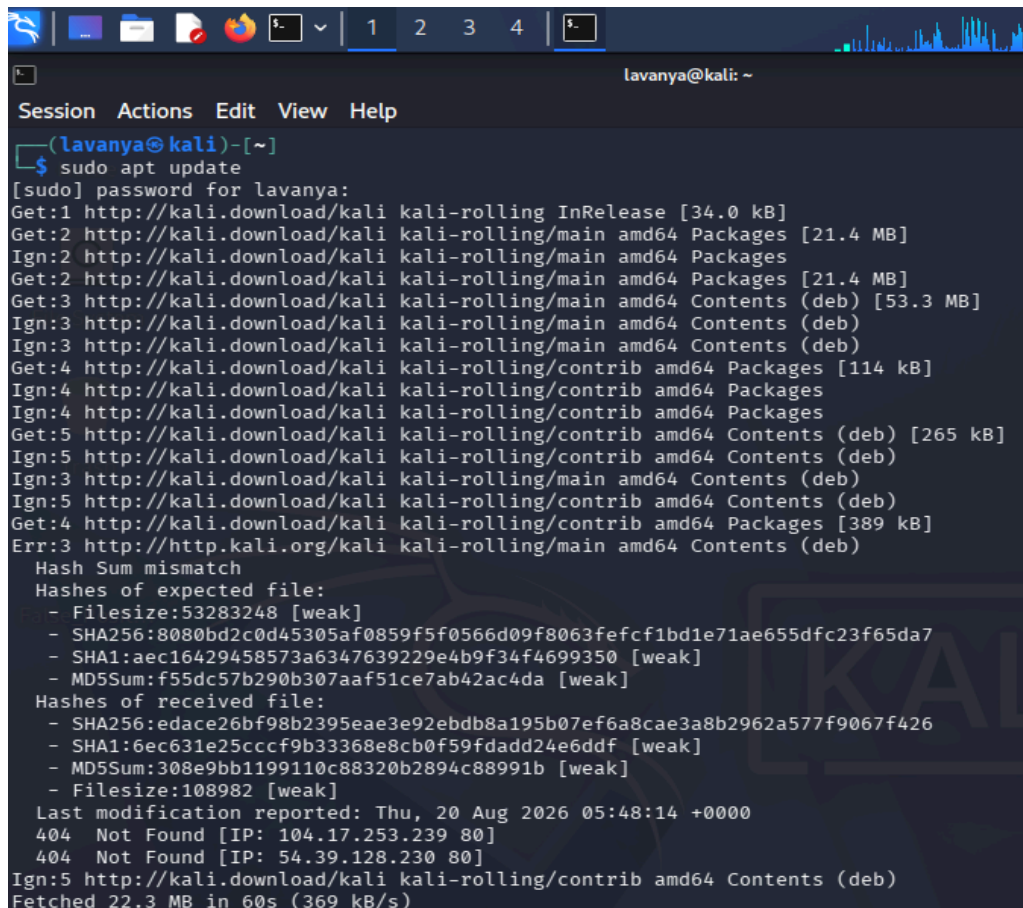
```
sudo apt install burpsuite sqlmap -y
```

Start Burp Suite:

burpsuite

Test an authorized vulnerable parameter:

sqlmap -u "http://TARGET_IP/page.php?id=1" --batch



```
lavanya@kali: ~  
Session Actions Edit View Help  
(lavanya@kali)~  
$ sudo apt update  
[sudo] password for lavanya:  
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]  
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]  
Ign:2 http://kali.download/kali kali-rolling/main amd64 Packages  
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]  
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]  
Ign:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb)  
Ign:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb)  
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]  
Ign:4 http://kali.download/kali kali-rolling/contrib amd64 Packages  
Ign:4 http://kali.download/kali kali-rolling/contrib amd64 Packages  
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [265 kB]  
Ign:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)  
Ign:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb)  
Ign:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)  
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [389 kB]  
Err:3 http://kali.org/kali kali-rolling/main amd64 Contents (deb)  
Hash Sum mismatch  
Hashes of expected file:  
- Filesize:53283248 [weak]  
- SHA256:8080bd2c0d45305af0859f5f0566d09f8063fefcf1bd1e71ae655dfc23f65da7  
- SHA1:aec16429458573a6347639229e4b9f34f4699350 [weak]  
- MD5Sum:f55dc57b290b307aaf51ce7ab42ac4da [weak]  
Hashes of received file:  
- SHA256:edace26bf98b2395eae3e92ebdb8a195b07ef6a8cae3a8b2962a577f9067f426  
- SHA1:6ec631e25ccccf9b33368e8cb0f59fdadd24e6ddf [weak]  
- MD5Sum:308e9bb1199110c88320b2894c88991b [weak]  
- Filesize:108982 [weak]  
Last modification reported: Thu, 20 Aug 2026 05:48:14 +0000  
404 Not Found [IP: 104.17.253.239 80]  
404 Not Found [IP: 54.39.128.230 80]  
Ign:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)  
Fetched 22.3 MB in 60s (369 kB/s)
```

Identify databases:

sqlmap -u "http://TARGET_IP/page.php?id=1" --dbs --batch

Identify tables:

sqlmap -u "http://TARGET_IP/page.php?id=1" -D DATABASE --tables --batch

Harmless XSS validation in Burp Suite:

```
<script>alert(1)</script>
```

Mitigation

- Use prepared statements/parameterized queries.
- Validate input using allowlists.
- Encode output before displaying it.
- Implement Content Security Policy (CSP).
- Use **HttpOnly**, **Secure**, and appropriate **SameSite** cookie settings.
- Do not expose database errors to users.
- Apply strong authentication and authorization.
- Regularly perform security testing.

3. Evil Twin Attack

Theory

An Evil Twin is a rogue wireless access point that imitates the legitimate network's SSID. A victim may accidentally connect to the fake access point. The attacker can then attempt to observe or manipulate traffic.

Weaknesses include reliance on a shared password, lack of certificate validation, insufficient wireless monitoring, and users trusting familiar SSIDs.

Commands

Install required tools:

```
sudo apt install aircrack-ng wireshark -y
```

Check wireless interface:

```
sudo iwconfig
```

Enable monitor mode in an authorized lab:

sudo airmon-ng check kill

sudo airmon-ng start wlan0

Discover wireless networks:

sudo airodump-ng wlan0mon

Start Wireshark:

wireshark

Stop monitor mode:

sudo airmon-ng stop wlan0mon

sudo systemctl restart NetworkManager

```
(lavanya@kali)-[~]
└─$ sudo apt install nmap nikto gobuster burpsuite -y
nmap is already the newest version (7.99+dfsg-1kali1).
nikto is already the newest version (1:2.6.0-0kali4).
nikto set to manually installed.
gobuster is already the newest version (3.8.2-1).
gobuster set to manually installed.
Upgrading:
  burpsuite
Summary:
  Upgrading: 1, Installing: 0, Removing: 0, Not Upgrading: 1065
  Download size: 341 MB
  Space needed: 22.7 MB / 29.5 GB available

Get:1 http://mirrors.esto.network/kali kali-rolling/main amd64 burpsuite amd64 2026.7.2-0kali1 amd64.deb 341 kB
Fetched 341 MB in 5min 0s (1,136 kB/s)
(Reading database... 427956 files and directories currently installed.)
Preparing to unpack .../burpsuite_2026.7.2-0kali1_amd64.deb...
Unpacking burpsuite (2026.7.2-0kali1) over (2026.3.2-0kali1)...
Setting up burpsuite (2026.7.2-0kali1)...
Processing triggers for kali-menu (2026.2.6)...

(lavanya@kali)-[~]
└─$ nmap -sV -sC TARGET_IP
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 11:31 +0530
Failed to resolve "TARGET_IP".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 2.81 seconds
```

Mitigation

- Prefer WPA3-Enterprise/802.1X for organizations.
- Use certificate-based authentication.
- Deploy Wireless IDS/IPS.
- Monitor for unauthorized access points.
- Segment guest and corporate networks.
- Educate employees not to trust unexpected login pages.
- Use VPNs for sensitive communications.

4. Wireless-to-Web Application Attack Chain

Theory

The attack can occur in several stages:

Wi-Fi compromise → Reconnaissance → Scanning → Web vulnerability discovery → Exploitation → Privilege escalation → Data access

After gaining access to a weakly protected wireless network, an attacker can identify hosts using network scanning. The attacker may then discover the employee management application's open ports and directories. Poor authentication or session management can allow unauthorized access or privilege escalation.

Commands

Find the wireless interface:

```
sudo iwconfig
```

Discover active hosts in the authorized lab network:

```
sudo nmap -sn 192.168.1.0/24
```

Scan the authorized web server:

```
sudo nmap -sV -sC TARGET_IP
```

Identify web-server vulnerabilities:

```
nikto -h http://TARGET_IP
```

Discover directories:

```
gobuster dir -u http://TARGET_IP -w /usr/share/wordlists/dirb/common.txt
```

Open Burp Suite:

```
burpsuite
```

Check for known vulnerabilities:

```
nmap --script vuln TARGET_IP
```

Defense-in-Depth

Wireless layer

- WPA3/802.1X
- Strong authentication
- Network segmentation
- Wireless monitoring

Web layer

- Strong authentication
- Role-based access control
- Secure session management
- Input validation
- Output encoding

Network layer

- Firewall
- IDS/IPS

- VLAN segmentation
- Continuous monitoring

```

Session Actions Edit View Help
(lavanya@kali)-[~]
$ sudo apt update
[sudo] password for lavanya:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Ign:2 http://kali.download/kali kali-rolling/main amd64 Packages
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Ign:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]
Ign:4 http://kali.download/kali kali-rolling/contrib amd64 Packages
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [265 kB]
Ign:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)
Get:6 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Ign:6 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Get:7 http://kali.download/kali kali-rolling/contrib amd64 Packages [389 kB]
Err:3 http://http.kali.org/kali kali-rolling/main amd64 Contents (deb)
Hash Sum mismatch
Hashes of expected file:
- Filesize:53283248 [weak]
- SHA256:8080bd2c0d45305af0859f5f0566d09f8063fefcf1bd1e71ae655dfc23f65da7
- SHA1:aec16429458573a6347639229e4b9f34f4699350 [weak]
- MD5Sum:f55dc57b290b307aaf51ce7ab42ac4da [weak]
Hashes of received file:
- SHA256:edace26bf98b2395eae3e92ebdb8a195b07ef6a8cae3a8b2962a577f9067f426
- SHA1:6ec631e25ccccf9b33368e8cb0f59fdadd24e6ddf [weak]
- MD5Sum:308e9bb1199110c88320b2894c88991b [weak]
- Filesize:108982 [weak]
Last modification reported: Thu, 20 Aug 2026 05:48:14 +0000
404 Not Found [IP: 104.17.253.239 80]
404 Not Found [IP: 54.39.128.230 80]
Ign:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)
Fetched 22.3 MB in 60s (369 kB/s)

```

5. Wireless Deauthentication Attack

Theory

A deauthentication attack abuses Wi-Fi management frames to force legitimate clients to disconnect from an access point. Repeated deauthentication can cause Denial of Service (DoS) and reduce network availability.

The main impact is:

- Availability: Users repeatedly lose network connectivity.
- Productivity: Employees/students cannot access network resources.
- Business impact: Network-dependent services may become unavailable.

Commands for controlled lab analysis

Install Aircrack-ng and Wireshark:

```
sudo apt install aircrack-ng wireshark -y
```

Check wireless interface:

```
sudo iwconfig
```

Enable monitor mode:

```
sudo airmon-ng check kill
```

```
sudo airmon-ng start wlan0
```

Observe wireless traffic:

```
sudo airodump-ng wlan0mon
```

Open Wireshark:

```
wireshark
```

Wireshark filter for deauthentication frames:

```
wlan.fc.type_subtype == 0x0c
```

Stop monitor mode:

```
sudo airmon-ng stop wlan0mon
```

```
sudo systemctl restart NetworkManager
```